

MODULE 20 · DOMAIN 4 - DATA SECURITY AND GOVERNANCE

Governance and sharing

Classification, PII and PHI, sharing inside and outside, data sovereignty, and SageMaker Catalog projects.

DOMAIN 4 of 4 EXAM WEIGHT 18% MODULE 20 of 27

Security asks **can** they. Governance asks **should** they, and **who decided**.

What a governance framework covers

- ◆ **Classification.** What kind of data is this, and how sensitive.
- ◆ **Ownership.** Who is accountable for it, not merely who built the pipeline.
- ◆ **Access decisions.** Who approves, on what basis, and where it is recorded.
- ◆ **Lineage and quality.** Where it came from and whether it can be trusted.
- ◆ **Retention and deletion.** How long it lives and how it goes away.
- ◆ **Every one of these has appeared in this course** as a technical control.

ON THE EXAM

Skill 4.5.7 names governance frameworks. The exam tests whether you can map each concern onto an AWS mechanism.

Classifying data

LEVEL	TYPICAL TREATMENT
Public	No restriction. Published deliberately
Internal	Available across the organisation, not outside it
Confidential	Restricted to named teams. Access requested and approved
Restricted or regulated	PII, PHI, cardholder data. Encryption, masking, audit, retention rules

ON THE EXAM

The scheme matters less than applying it consistently. Four levels used properly beats twelve used inconsistently.

Making a classification do something

- ◆ **An LF-Tag** carrying the classification, attached to the table or column.
- ◆ **Grants against the tag**, so a new restricted table is protected on creation.
- ◆ **An S3 object tag** driving a lifecycle rule and a bucket policy condition.
- ◆ **A glossary term in the catalog**, so humans see the classification too.
- ◆ **A classification recorded only in a spreadsheet** enforces nothing.

ON THE EXAM

The point of classifying is that the label drives the control. A label nothing reads is documentation, not governance.

Central control or federated ownership?

CENTRALISED

One team decides

- Consistent policy, applied uniformly
- Small group holds the expertise
- Becomes a bottleneck as the estate grows
- Approvers often lack business context

FEDERATED

Domains own their data

- Owners decide, because they understand the data
- Scales with the organisation
- Needs guardrails so standards hold
- The model SageMaker Catalog implements

THE TIEBREAKER

Central policy, federated decisions. The platform team owns the rules; domain owners apply them to their own data.

Personal and health information

- ◆ PII identifies a person. Name, address, national identifier, email.
- ◆ PHI is health information tied to an individual, under stricter regimes.
- ◆ **Combinations identify too.** A postcode, a birth date and a gender often suffice.
- ◆ **Discovery first**, because it appears where nobody expects it.
- ◆ **Then classify, then apply the controls** the classification implies.

ON THE EXAM

The third point defeats naive redaction. Removing the name does not anonymise a record that still pins down one person.

What the regimes actually require

CONCERN	WHAT IT IMPLIES TECHNICALLY
Lawful basis and purpose	Access decisions recorded, with a stated purpose
Data minimisation	Collect and retain only what is needed. Retention rules
Right to erasure	Forward lineage, and row-level deletion capability
Breach notification	Detection and audit logs, so scope is establishable
Residency	Region choice, and every derived copy accounted for

ON THE EXAM

The exam does not test legislation. It tests which AWS mechanism satisfies a requirement stated in business terms.

A company is building a governance model for a lake with several hundred tables. It wants a dataset classified as restricted to automatically be encrypted with a customer managed key, hidden from general analyst roles, and retained for seven years.

The team currently records classifications in a shared spreadsheet, and applies the controls by hand when a table is created.

What should the data engineer implement?

- ☐ A Move the spreadsheet into a wiki so it is easier to find
- ☐ B Apply the classification as an LF-Tag and an S3 object tag, with Lake Formation grants and lifecycle rules written against the tag values
- ☐ C Write a runbook describing the manual steps for each classification level
- ☐ D Create a separate AWS account per classification level

◆ PAUSE AND DECIDE

What should the data engineer implement?

- A

Move it to a wiki

Improves how easy the record is to read. Nothing acts on it, so no control is applied by classifying anything.
- B

Tags driving grants and lifecycle rules

The label becomes the control. Tagging a new table as restricted applies the access rules and the retention rule with no further action.
- C

A runbook

Documents the manual steps rather than removing them. The step somebody forgets is still the step that fails.
- D

An account per classification

A strong boundary and a large change, and it does not express column-level restriction within a dataset.

THE SIGNAL

"Automatically" is the word. A classification that requires somebody to act on it is not automatic.

Ownership, and who decides

- ◆ **A data owner** is accountable for a dataset, and is rarely the engineer who built it.
- ◆ **Owners approve access**, because they understand what the data means.
- ◆ **A data steward** maintains its quality, classification and documentation.
- ◆ **A platform team approving everything** becomes a bottleneck and a rubber stamp.
- ◆ **Record the decision with the asset**, not in an email thread.

ON THE EXAM

The platform team owns the mechanism. The business owns the decision. Conflating them produces slow, uninformed approvals.

Sharing inside an organisation and sharing outside it are **different problems**.

Receiving data from outside

- ◆ **Subscribed data arrives in your account**, and becomes your governance problem.
- ◆ **Classify it on arrival**, because a supplier's classification is not yours.
- ◆ **Licence terms constrain use**, including onward sharing and retention.
- ◆ **Catalogue it like any other dataset**, so consumers can find and trust it.
- ◆ **Revisions arrive automatically**, so downstream pipelines must handle change.

ON THE EXAM

Third-party data is not exempt from your governance model. It joins it, with extra constraints attached.

The sharing mechanisms

MECHANISM	BEST FOR
Lake Formation cross-account	Catalog tables, with column and row filters preserved
Redshift data sharing	Live warehouse data across clusters and accounts
S3 Access Points	A named endpoint and policy per consumer of a bucket
SageMaker Catalog subscription	Discovery and request-approve inside the organisation
AWS Data Exchange	Publishing datasets to external subscribers, including commercially
A copy	Always available, always the worst option

ON THE EXAM

The last row is there because it is the default people reach for. Every other row avoids a second copy.

AWS Data Exchange

- ◆ **A marketplace for datasets**, newly in scope for this exam.
- ◆ **Subscribe to third-party data** and receive it into your own account.
- ◆ **Publish your own data** to named subscribers or commercially.
- ◆ **Delivery to S3, or through Redshift data sharing and APIs.**
- ◆ **Entitlements and revisions are managed**, so subscribers get updates automatically.

ON THE EXAM

The signal is an external party, especially a commercial relationship. Data Exchange handles entitlement and delivery.

Sharing inside or outside?

INSIDE THE ORGANISATION

You control both sides

- Federated identity from one directory
- Lake Formation, datashares, access points
- Subscription workflow in the catalog
- Governance is a shared policy

OUTSIDE THE ORGANISATION

They control theirs

- Their accounts, their identities
- Data Exchange, or cross-account with RAM
- Entitlement has a start and an end
- Governance is a contract

THE TIEBREAKER

Cross-account sharing works either way. What changes outside is entitlement, commercial terms and revocation.

A market data company wants to sell a curated dataset to around two hundred external customers. Subscribers should receive monthly revisions automatically, access should end when a subscription lapses, and the company does not want to build billing or entitlement management.

A proposal is to create an S3 bucket per customer and copy the dataset into each one after every monthly build.

What should the data engineer recommend instead?

- ☐ A AWS Data Exchange, publishing the dataset with managed entitlements and revisions
- ☐ B Lake Formation cross-account grants to each of the two hundred customer accounts
- ☐ C One shared bucket with a bucket policy listing all two hundred accounts
- ☐ D Keep the per-customer buckets but automate the copying with a Glue job

◆ PAUSE AND DECIDE

What should the data engineer recommend instead?

- A** AWS Data Exchange
Entitlement, revisions, subscription lifecycle and delivery are the product. None of it has to be built.
- B** Two hundred Lake Formation grants
Technically workable, and it leaves billing, entitlement and lapse handling entirely to you.
- C** One bucket policy naming 200 accounts
A policy that size is unmaintainable and hits size limits, and it manages no subscription lifecycle.
- D** Automate the copying
Two hundred copies, automated. The duplication, the storage and the revocation problem all remain.

THE SIGNAL

Billing, entitlement and lapse are named in the requirement. Those words are the Data Exchange signal.

Some data is not allowed to **leave a place**,
and that is a design constraint.

Controlling where data lives

- ◆ **Choose the Region** and everything stays there unless you move it deliberately.
- ◆ **SCPs can restrict which Regions** an account may use at all.
- ◆ **Cross-Region replication moves data**, and so does a global table or a global database.
- ◆ **Watch the derived copies.** Backups, logs and query results have Regions too.
- ◆ **AWS Dedicated Local Zones** place infrastructure in a customer-specified location.

ON THE EXAM

The fourth point is where sovereignty programmes fail. The dataset stayed put and its backup did not.

Sovereignty beyond location

- ◆ **Where the data sits** is the first question, and not the only one.
- ◆ **Who can access it operationally**, including support personnel.
- ◆ **Who holds the encryption keys**, which is why external key stores exist.
- ◆ **Where metadata and logs go**, which is often overlooked entirely.
- ◆ A Region choice answers the first. The rest need deliberate design.

ON THE EXAM

Modern sovereignty requirements ask who operates the infrastructure, not only which country it stands in.

The AWS European Sovereign Cloud

- ◆ Generally available since 15 January 2026, in Brandenburg, Germany.
- ◆ Physically and logically separate from all other AWS Regions.
- ◆ Its own IAM, billing, logging and governance, independent of the global partitions.
- ◆ Operated by EU-resident personnel under EU-incorporated entities.
- ◆ Neither customer data nor operational metadata leaves the EU.

ON THE EXAM

This is newer than the exam guide. Recognise it as the strongest sovereignty option, and answer questions from the guide.

A healthcare provider must keep patient data within a single country. The data lake and Redshift warehouse are correctly deployed in the required Region and access is restricted appropriately.

An audit has found three issues. Redshift snapshots are copied to a second Region for disaster recovery, Glue job logs are delivered to a log archive account in another Region, and an Athena workgroup writes query results to a bucket created years ago in a third Region.

What is the underlying problem, and what should be done?

- | | |
|--|---|
| <p>A Derived copies inherit the residency requirement. Bring snapshots, logs and results into the required Region and use an SCP to restrict Region use</p> | <p>B Encrypt the snapshots, logs and results so their location no longer matters</p> |
| <p>C Delete the disaster recovery copies and accept the reduced resilience</p> | <p>D Apply Lake Formation column-level permissions to the affected tables</p> |

◆ PAUSE AND DECIDE

What is the underlying problem, and what should be done?

- A** Derived copies inherit residency. Relocate them and restrict Regions
All three findings are copies of regulated data outside the boundary. An SCP prevents the next one being created.
- B** Encrypt them instead
Residency is about where data physically is. Encrypted regulated data in the wrong country is still in the wrong country.
- C** Delete the DR copies
Addresses one of three findings by removing a resilience capability, rather than relocating it.
- D** Column-level permissions
Controls who sees which columns. It has nothing to do with where the bytes are stored.

THE SIGNAL

Three findings, one cause. Every one is a derived artefact that inherited the data's sensitivity but not its constraints.

Governance works when access follows
the work, not the person.

Domains, projects and subscriptions

- ◆ **A domain** is the governance boundary. Usually a business unit or the organisation.
- ◆ **Domain units** subdivide it to mirror how teams are structured.
- ◆ **A project** is a piece of work, with members, tools and subscriptions.
- ◆ **Joining a project grants its access.** Leaving removes it.
- ◆ **Lake Formation permissions are applied underneath**, so enforcement is the same.

ON THE EXAM

The last point matters. This is a governance layer over the mechanisms modules 18 and 19 covered, not a replacement.

How access actually gets granted

01

Publish

A producer publishes a dataset as an asset, with description and classification.

02

Discover

A consumer searches the catalog and finds it.

03

Request

Their project requests a subscription, stating the purpose.

04

Approve

The data owner approves or refuses, and the decision is recorded.

05

Grant

Lake Formation permissions are applied to the project's role automatically.

ON THE EXAM

Every step leaves a record. That is what makes the access decision auditable rather than remembered.

Trust, and how a consumer judges it

- ◆ **A description and an owner**, so a consumer knows what it is and who to ask.
- ◆ **Quality scores from module fifteen**, published with the asset.
- ◆ **Lineage**, so provenance is visible before anyone depends on it.
- ◆ **Freshness**, because a correct dataset that stopped updating is still wrong.
- ◆ **Without these, consumers pick a dataset by asking a colleague** which one is right.

ON THE EXAM

The last bullet is how most organisations actually work, and it is why nine plausible tables all get used differently.

Lineage for compliance

- ◆ **Trace a figure back** through every transformation to its source.
- ◆ **Versioned**, so you can show the lineage as it stood when a report was published.
- ◆ **Trace forward** to show where personal data flowed after ingestion.
- ◆ **That forward trace** is what makes an erasure request answerable.
- ◆ **Column level**, so a single sensitive field can be followed.

ON THE EXAM

Module twelve covered lineage as an engineering tool. Skill 4.5.3 names it for compliance, which is the forward direction.

Proving it to somebody else

- ◆ **An auditor asks for evidence**, not for a description of the design.
- ◆ **CloudTrail** shows who changed a permission, and when.
- ◆ **The subscription record** shows who requested access and who approved.
- ◆ **Lineage** shows where a published figure came from.
- ◆ **Object Lock on log archives** shows the evidence itself was not altered.

ON THE EXAM

Every layer of this domain produces evidence. Governance is largely the practice of keeping it and being able to find it.

A bank must respond to customer erasure requests within thirty days. Customer records enter through three ingestion pipelines and are derived into an unknown number of downstream tables, dashboards and extracts across four accounts.

The team currently answers each request by asking every data owner whether they hold data for that customer, which takes weeks and is not provably complete.

What should the bank implement?

- A Column-level data lineage in SageMaker Catalog, to trace forward from the ingestion points to every derived dataset
- B Amazon Macie, to scan every bucket for the customer's identifiers on each request
- C An AWS Config rule that reports which datasets contain personal data
- D Object Lock on the ingestion buckets, so the source records cannot be altered

◆ PAUSE AND DECIDE

What should the bank implement?

- A

 Column-level lineage, traced forward
The question is which datasets derive from these sources. Lineage answers it structurally, once, rather than per request.
- B

 Macie per request
Macie finds sensitive data types by pattern, not one named individual, and scanning an estate per request is slow and costly.
- C

 A Config rule
Config evaluates resource configuration against rules. It does not inspect dataset contents or derivation.
- D

 Object Lock on ingestion
Makes the source records undeletable, which is the opposite of what an erasure obligation requires.

THE SIGNAL

"An unknown number of downstream datasets" is the lineage signal. The problem is not finding data, it is knowing where it went.

Where governance meets engineering

- ◆ **A policy is a sentence.** A control is something that refuses a request.
- ◆ **The engineering job** is turning the first into the second.
- ◆ **Policies without controls** are discovered to be untrue during an audit.
- ◆ **Controls without policies** are arbitrary, and get removed when inconvenient.
- ◆ **Both, plus the evidence,** is what a governed platform actually means.

ON THE EXAM

Every worked scenario in this module took a policy statement and asked which mechanism enforces it.

Bringing Domain 4 together

- ◆ **Authentication** establishes who, with roles rather than stored credentials.
- ◆ **Authorisation** decides what, with Lake Formation for columns and rows.
- ◆ **Encryption** protects the bytes; **masking** protects them from insiders.
- ◆ **Governance** records who decided, and why, and proves it later.
- ◆ **A question usually names one layer.** Answering in the wrong one is the common error.

ON THE EXAM

Four layers, four modules. Most Domain 4 questions are answerable once you identify which layer is being asked about.

Symptoms and their causes

SYMPTOM	LIKELY CAUSE
Classification exists but controls are inconsistent	The label lives in a document, not in a tag
Regulated data found in another Region	A derived copy. Snapshot, log or query result
Access requests take weeks	Central approval where a subscription workflow would delegate
Cannot prove why a team has access	Grants made directly, with no recorded decision
Erasure requests cannot be completed	No forward lineage from ingestion to derived datasets
Two hundred copies of one dataset	Sharing solved by duplication rather than by grants

ON THE EXAM

Every row is a governance failure with a technical mechanism available. That mapping is what the exam tests.

Reading a governance question quickly

- ◆ **Which layer?** Authentication, authorisation, encryption or governance.
- ◆ **Does the label drive anything?** A classification nothing reads is documentation.
- ◆ **Inside or outside the organisation?** External and commercial means Data Exchange.
- ◆ **Where does the data physically live?** Including every derived copy.
- ◆ **Backwards or forwards?** Provenance and erasure are opposite lineage directions.

ON THE EXAM

Teaching content complete. Next: how DEA-C01 questions are written, then the December 2025 revision gap.